AssetTrust v0.60

Restricted PostgreSQL grants | Security and release assessment | 11 November 2026

RELEASE VERDICT: NO-GO - offline engineering checkpoint, not production approval.

What changed

The v0.59 CI runtime account was granted SELECT, INSERT, UPDATE and DELETE on every table, including the migration ledger and audit history. v0.60 narrows these internal permissions without rewriting existing database migrations.

Migration ledger: allow SELECT; deny INSERT, UPDATE and DELETE for the restricted test API login. **Audit history:** allow SELECT and append-only INSERT; deny UPDATE and DELETE.

A read-only PostgreSQL contract now inspects effective table permissions, role elevation flags, database/schema CREATE permissions and inherited role memberships. An opt-in repair command is available only for explicitly approved local disposable test databases.

Tests and evidence

Check	Result	Meaning
New v0.60 tests	15 / 15 pass	Offline policy and safety tests
Version regression	58 / 58 pass	v0.03-v0.60; exit codes recorded
SQL migrations	25 / 25 match	Identical to v0.59 source
CI / architecture / syntax	Pass	Static checks, not installed-build evidence
Live PostgreSQL grant audit	Not run	Database service unavailable here
Genuine npm install / build	Blocked	No lockfile, dependencies or registry
ClamAV / browser / Git history	Not run	Requires connected Kali environment

Scope and limitations

These changes secure the **disposable CI API role**. They do not automatically modify a deployed production role. The seven previously implemented RLS tables still require real PostgreSQL verification; other sensitive data tables may retain broad access. The new test validates role permissions, not end-to-end tenant isolation or legal title verification.

Release requirements

1. Review and generate an authentic npm lockfile; successfully run npm ci, build, unit and vulnerability checks.
2. Run the effective-grant audit and seeded cross-organization RLS/CRUD tests using a restricted database role on Kali.
3. Inventory remaining unprotected sensitive tables; design and verify production least-privilege/RLS controls.
4. Complete ClamAV, two-API, authenticated browser, Git-history, TLS and deployment security validation.
5. Perform backup/restore, independent security review and formal approval before real customer use.

Decision: No production deployment or commercial handling of real asset/customer records until the required live evidence is complete.